SOC L1 LAB · INC-005

Detection, Mitigation, and Triage Guide — INC-005

A scan is a question, not a verdict

INCIDENT	INC-005 — Outbound port scan
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	Medium

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Detection model
2. Rule analysis
3. Triage playbook
4. Severity matrix
5. Containment and mitigation
6. Escalation template
7. Post-incident
8. Common mistakes
9. Coverage map
10. Metrics

Audience: an L1 analyst who receives the alert, and an L2 or detection engineer who owns the network rule.

This guide uses INC-005 as the worked example. Wazuh rule 86601 is stock; the Suricata rule is local.

---

1. Detection model

A port scan is a network event, but the decision needs three layers.

Layer	Source	Question	INC-005 evidence
Network	Suricata	Did a host sweep ports?	sid 1000001, 144 alerts
Host	auditd / FIM	Did the host do anything else?	none
Identity	sshd / sudo	Did someone log in or elevate?	none

If only the network layer fires, the finding is **reconnaissance**. The other layers decide whether it is a compromised host or an approved scanner.

1.1 Signal hierarchy

```
Low     one connection to one port
        ----  normal traffic

Medium  many SYNs in a short window
        ----  scan candidate; verify the source

High    scan + authentication failures / exploit attempts
        ----  likely compromised host

Critical scan + successful session / payload / lateral movement
```

---

2. Rule analysis

2.1 The local rule

```
alert tcp $HOME_NET any -> $EXTERNAL_NET any (
  msg:"LAB SCAN outbound SYN sweep";
  flags:S;
  detection_filter: track by_src, count 50, seconds 5;
  classtype:attempted-recon;
  sid:1000001; rev:1;
)
```

- **Direction:** `$HOME_NET -> $EXTERNAL_NET`. This is an **outbound** scan. ET Open's scan signatures are largely inbound (`$EXTERNAL_NET -> $HOME_NET`), so they missed the lab's outbound case.
- **`flags:S`:** counts SYN packets only, not established data.
- **`detection_filter`:** 50 SYNs from the same source in 5 seconds.
- **classtype:** `attempted-recon` (severity 2).

2.2 Why not rely on ET SCAN

ET Open has good scan signatures, but they are direction-sensitive and often target known tools/patterns. The outbound case needed an explicit rule. A production estate should use both: ET SCAN for inbound/known tools, a local rule for outbound discovery.

2.3 False-positive boundary

Traffic	Alerts
Normal `apt` + `curl`	0
40 requests in a burst	0
60 requests in a burst	10

The rule counts packets, not unique destinations. A busy client or load test crosses the threshold. Tuning options:

- raise the count (e.g., 100/5 s) and accept slower detection;
- baseline known scanners and load generators;
- correlate with authentication failures or process activity;
- use a flow-based detector for unique-destination counting.

2.4 Gaps

Gap	Consequence
Outbound-only	An inbound scan of the VM is not covered
Packet-count threshold	Legit bursts false-positive; slow scans evade
One destination	A subnet sweep is not represented
No follow-on correlation	Scan + exploit are separate alerts

---

3. Triage playbook

3.1 Five questions

1. **Who is the source?** Internal host, scanner, jump host, or unknown?
2. **What was scanned?** One host, a subnet, specific ports?
3. **Is it approved?** Scanner schedule, change ticket, asset inventory.
4. **What followed?** Auth failures, exploit attempts, new sessions, egress.

5. **Is the source healthy?** Process/file anomalies, unusual logins, malware alerts.

3.2 Decision tree

```
Port scan alert
│
├─ Source is a known scanner and the window is scheduled
│    └─ Close; verify scope and rate
│
├─ Source is an internal host, no approval
│    ├─ No follow-on activity → Medium; contact the owner
│    ├─ Auth failures / exploit attempts → High; isolate
│    └─ Session / payload / lateral movement → Critical
│
└─ Source is external
     ├─ Blocked by edge → informational
     └─ Reached an internal host → High; check exposure
```

3.3 Step by step

1. Confirm the direction: outbound or inbound.
2. Identify the source and destination from the alert.
3. Check the scanner inventory and change calendar.
4. Pivot to host telemetry for the source: logins, `sudo`, new processes, FIM changes.
5. Pivot to authentication logs for the destination.
6. Check for egress or a second stage.
7. Assign severity with §4.
8. Contain only if there is evidence of compromise; a scan alone does not justify isolating a production scanner.

---

4. Severity matrix

Situation	Severity
Approved scanner, scheduled window	Low / close
Internal host, no approval, no follow-on	Medium
Internal host + authentication failures	High
Internal host + exploit attempts	High
Scan + successful session / payload	Critical
External scan blocked at the edge	Low
External scan reaching an internal service	High

INC-005: internal host, no approval, no follow-on → **Medium**.

---

5. Containment and mitigation

5.1 During the incident

Action	When	Caution
Contact the host owner	Medium, no follow-on	Fastest path to "approved scanner"
Capture the flow/alert set	Always	Before rotating logs
Isolate the host	Only with compromise evidence	A scanner may be production
Block the source	External/edge only	Internal blocking can break monitoring
Check the destination	Always	Open ports may be the real finding

5.2 Hardening

- Maintain a scanner inventory with source addresses and schedules.
- Segment management/scanner traffic from user traffic.
- Restrict egress from the web tier.
- Alert on scan → auth-failure sequences.
- Add the inbound rule if the sensor sees inbound traffic.
- Keep the IDS feed and rule thresholds reviewed.

5.3 Detection controls

Control	Purpose
Local outbound rule	Catches the direction ET misses
ET SCAN rules	Known tools and inbound scans
5710/5760/5763	Follow-on authentication attempts
80792 / FIM	Host activity after the scan
86601	Wazuh ingestion of Suricata alerts

---

6. Escalation template

```
INC-005 — Outbound port scan

What:  10.0.2.15 scanned 200 TCP ports on 10.0.2.2 at 23:26:35 UTC. 144 Suricata
       alerts, signature LAB SCAN outbound SYN sweep (sid 1000001).
Scope: Source is the lab VM; destination is the gateway. One host, one target.
Follow: No authentication, file change, process execution, or egress observed.
Done:  Evidence preserved; no containment (recon only).
Ask:   (1) Was a scan scheduled for this host? (2) If not, review host telemetry for
       compromise. (3) Should the threshold be raised for the load-test window?
```

7. Post-incident

- Update the scanner inventory or the threshold.
- Add the scan + auth-failure correlation test.
- If the bridge upgrade is deployed, add the inbound case.
- Review whether the 50/5 s threshold is right for the estate.
- Document the direction limitation in the runbook.

8. Common mistakes

Mistake	Consequence
Treating a scan as a breach	Wasted isolation, angry scanner owner
Closing because "it is just recon"	Misses a compromised host doing discovery
Relying only on ET SCAN	Outbound scans are missed
Ignoring the destination	The open port may be the real issue
Raising the threshold without a baseline	Slow scans evade; load tests still fire
Blocking an internal scanner	Breaks security operations

9. Coverage map

Technique	ID	Covered by	Gap
Network service discovery	T1046	sid 1000001, ET SCAN	Outbound-only local rule
Active scanning	T1595	sid 1000001	Slow/distributed scans
Follow-on auth	T1110	5710/5760/5763	Needs correlation
Exploitation	T1190	Suricata web rules	Not in this scenario

10. Metrics

Metric	INC-005
Normal traffic alerts	0
40-request burst	0
60-request burst	10 (FP)
Scan alerts	144
Time from scan to Wazuh	~1 s
Follow-on activity	none
Severity	Medium

The detection is fast. The judgement is whether the source is allowed to scan.